

网络安全（实验部分）

北京邮电大学
网络空间安全学院
武斌



本课程的目的

- 《网络安全（实验部分）》旨在使学生在理解网络安全基本理论之上，进一步加强实际动手能力
 - ➔ 编程
 - ➔ 协议分析
 - ➔ 网络安全技术
- 学完本课程应达到的水平
 - ➔ 实践密码学基础、网络安全技术原理
 - ➔ 能够熟练使用经典的网络攻击工具和防御技术
 - ➔ 深入理解网络安全技术，并能进一步灵活运用



学习本课程的基础

- 有一定的信息与网络安全基础
 - ➔ 密码算法及协议
 - ➔ 网络攻防技术
- 有一定的计算机网络基础
 - ➔ 网络协议（TCP/IP协议）
 - ➔ 网络结构，交换机、路由器等设备
- 有一定的编程基础（C、C++）
 - ➔ 熟悉API函数
 - ➔ 核心编程



课程安排

- 网络攻击技术

- ARP欺骗实验
- 拒绝服务攻击
- 安全漏洞扫描

- 网络防御技术

- 防火墙
- 入侵检测系统
- VPN
- WEB安全
- 电子邮件安全



课程的初步安排

- 第一阶段（讲授）

- ➔ 内容：知识和技术原理、实验要求

- 第二阶段（实验）

- ➔ 内容：编程、应用、分析等动手实践



考核方式

- 平时考勤
- 课堂实验
- 实验报告



本次课程学习目标

学习完本次课程，您应该能够掌握：

- ARP协议简介
- ARP欺骗攻击原理
- ARP欺骗防范技术
- ARP欺骗攻击工具实验
- ARP欺骗攻击编程实验





本次课程内容

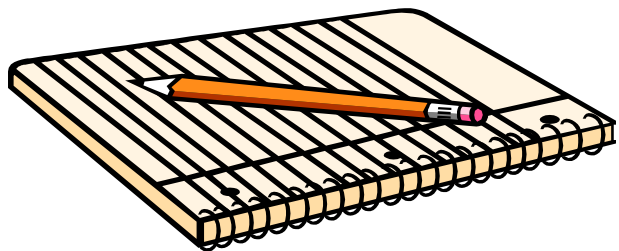
● ARP协议简介

● ARP欺骗攻击原理

● ARP欺骗防范技术

● ARP欺骗攻击工具实验

● ARP欺骗攻击编程实验





ARP协议

- ARP (Address Resolution Protocol)

地址解析协议

完成IP地址到网络地址的动态映射。



ARP缓存表

- ▶ 每台主机的ARP缓存表中都存放了在该局域网中所有主机的IP地址和MAC地址的一一映射关系，其中也包括路由器的IP和MAC映射。
- ▶ 为了节省ARP缓冲区内内存，被解析过的ARP条目的寿命都是有限的。如果一段时间内（一般为20分钟）该条目没有被参考过，则条目被自动删除。
- ▶ “ARP -a” 命令查看
- ▶ “ARP -d” 命令清空

```
管理员: 命令提示符
Microsoft Windows [版本 6.1.7601]
版权所有 (c) 2009 Microsoft Corporation。保留所有权利。

C:\Users\wubin>arp -a

接口: 59.64.157.208 --- 0xa
Internet 地址          物理地址          类型
59.64.156.1            00-04-96-18-d9-a0 动态
230.0.0.1              01-00-5e-00-00-01 静态

C:\Users\wubin>
```

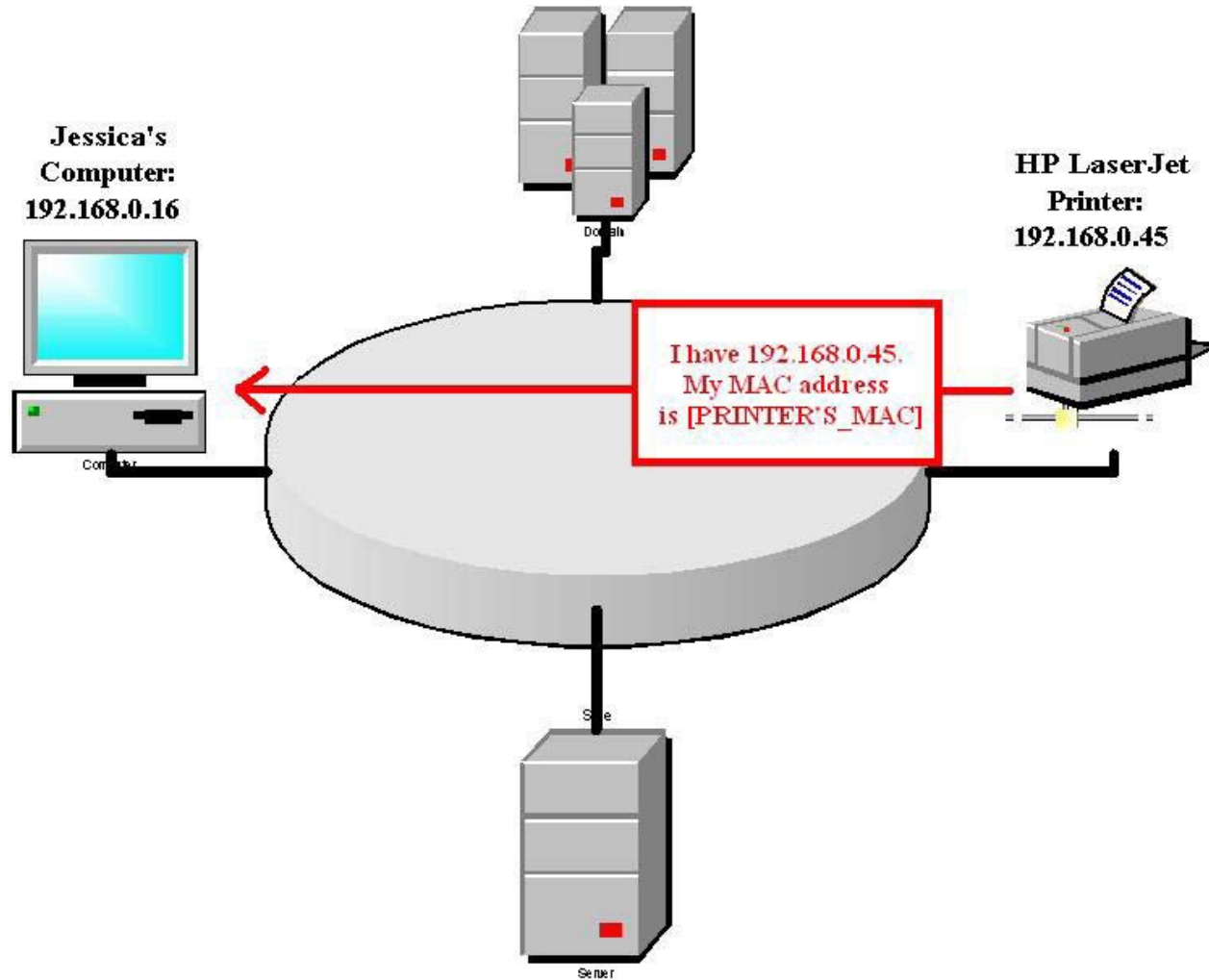


ARP协议工作过程

- 源主机**A**首先判断目的主机**B**是否处于同一子网（根据本子网的子网掩码和目标主机**IP**地址）。
- 若目的主机位于同一子网内
 - 主机**A**先检查**ARP**缓存内是否有主机**B**的**MAC**地址。
 - 如果没有，主机**A**会发送一个**ARP**请求广播包，此包内包含着其欲与之通信的主机的**IP**地址，也就是主机**B**的**IP**地址。
 - 当主机**B**收到此广播后，会将自己的**MAC**地址利用**ARP**响应包传给主机**A**，并更新自己的**ARP**缓存，也就是同时将主机**A**的**IP**地址/**MAC**地址对保存起来，以供后面使用。
 - 主机**A**在得到主机**B**的**MAC**地址后，就可以与主机**B**通信了。同时，主机**A**也将主机**B**的**IP**地址/**MAC**地址对保存在自己的**ARP**缓存内。



ARP工作过程示例





ARP包格式

目标以太网地址	源以太网地址	帧类型 (0x0806)	帧数据
6字节	6字节	2字节	28字节

0	16	32
硬件类型		协议类型
硬件地址长度	协议地址长度	操作码
源硬件地址		
		源IP地址
源IP地址		
目的硬件地址		
目的IP地址		



ARP相关协议及应用

- RARP（反向ARP）

局域网的物理机器从网关服务器的 **ARP** 表或者缓存上请求其 **IP** 地址，广泛用于获取无盘工作站的**IP**地址。

- 代理ARP

通过使用一个主机（通常为**router**），来作为指定的设备对另一设备的**ARP**请求作出应答。

- 无故ARP（Gratuitous ARP, GARP）

主机有时会使用自己的**IP**地址作为目标地址发送**ARP**请求。主要用来检测**IP**的地址是否有冲突。



ARP协议的安全问题

- ARP协议是建立在信任局域网内所有结点的基础上的，它高效，但却不安全。
- ARP高速缓存根据所接收到的ARP协议包随时进行动态更新，它是**无状态的协议**，不会检查自己是否发过请求包，只要收到目标MAC是自己的ARP响应数据包或ARP广播包，都会接受并缓存。
- ARP协议没有认证机制，只要接收到的协议包是有效的，主机就无条件地根据协议包的内容刷新本机ARP缓存，并不检查该协议包的合法性。
- 因此攻击者可以随时发送虚假ARP包更新被攻击主机上的ARP缓存，进行地址欺骗或拒绝服务攻击。



ARP欺骗攻击

- ARP Reply Spoofing

- 构造虚假的ARP响应包，篡改目标主机的MAC地址
- 将网关的MAC地址设为广播地址

- MAC flooding: Switch

- Sniffing

- MAC地址克隆

- ARP中间人攻击



ARP欺骗的防范

- 静态ARP绑定

- ARP防护软件

ARP防火墙、ARPwatch nbtscan

- ARP防护功能的网络设备

- 动态ARP检测（DAI）

交换机记录每个接口的IP和MAC，形成port-MAC-IP表，检测ARP响应包

- DHCP监听（DHCP Snooping） DHCP监听绑定表（DHCP Snooping Binding）



ARP欺骗实验内容

- 工具实验：运行WinArpAttacker或Ettercap（二选一），通过WireShark等抓包工具，捕获ARP欺骗攻击的数据包，分析ARP攻击的原理。
- 编程实验：基于Winpcap（或其它网络开发包Libpcap/Jpcap/Scapy等）编写程序，对指定的目标IP地址进行ARP欺骗攻击。



ARP欺骗攻击工具实验要求

- 选择Ettercap或WInArpAttacker工具实验进行ARP欺骗操作，完成以下实验步骤并截图，对过程中捕获的数据包进行分析，分析攻击的原理，形成实验报告：
 - ➔ 查看虚拟机IP信息以及ARP缓存表，并测试互ping情况；
 - ➔ 使用Ettercap或WInArpAttacker扫描在线主机并找到靶机；
 - ➔ 根据软件功能实施“禁止上网”、“中间人”、“IP冲突”等攻击；



ARP欺骗攻击编程实验

- 选择Winpcap（或其它网络开发包Libpcap/Jpcap/Scapy等）编写程序，完成以下步骤：
 - ➔ 查看本机、受害者虚拟机以及网关的IP和物理地址，以及ARP缓存表，测试连通情况；
 - ➔ 定义ARP数据包；
 - ➔ 根据IP和物理地址构造ARP欺骗包；（实现禁止上网or中间人or IP冲突攻击）
 - ➔ 发送ARP欺骗包,查看攻击成功后的arp缓存表和上网状态等



01

工具实验

选择WinArpAttacker或Ettercap之一
进行实验



Ettercap

✓ 攻击机

Kali-linux 2022.3

✓ 靶机

windows xp

✓ 软件

ettercap-0.8.31 , wireshark

查看攻击前信息

使用命令ipconfig /all (或 ifconfig) 查看虚拟机网卡、ip地址、网关地址等信息。两虚拟机之间应能互相ping通。利用命令arp -a查看靶机被攻击前的arp信息。

```
C:\WINDOWS\system32\cmd.exe

Ethernet adapter 本地连接:

    Connection-specific DNS Suffix  . : localdomain
    Description . . . . . : VMware Accelerated AMD PCNet Adapter
    Physical Address. . . . . : 00-0C-29-A0-F7-83
    Dhcp Enabled. . . . . : Yes
    Autoconfiguration Enabled . . . . : Yes
    IP Address. . . . . : 192.168.174.129
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.174.254
    DHCP Server . . . . . : 192.168.174.254
    DNS Servers . . . . . : 8.8.8.8
    Primary WINS Server . . . . . : 192.168.174.2
```

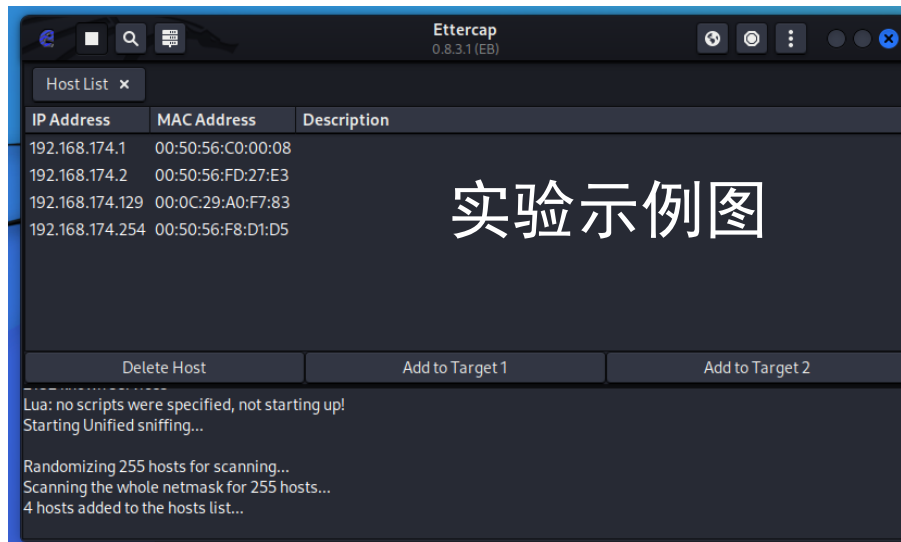
实验示例图



Ettercap

设置攻击对象

在kali中，使用命令`sudo ettercap -G`打开ettercap。选择当前网卡，点击左上角🔍，扫描该网段的所有主机信息，在host list中查看扫描结果。分别将靶机IP和网关地址设为目标1和目标2





Ettercap

开始攻击

在MITM菜单中选择ARP Poisoning，点击ok开始攻击，日志如下。然后

实验示例图

实验示例图

查看攻击效果

1. 查看被arp投毒后的靶机arp信息。
2. 启动wireshark抓包，实验结果中应用发起arp欺骗攻击的数据包，以及攻击成功后截获的靶机网络流量。



WinArpAttacker



实验环境

实验需要准备三个windows XP SP3虚拟机，分别为：

①XP1（攻击方）

②XP2（靶机）

③XP3（靶机）

将虚拟机的网络工作模式设置为桥接，并且将虚拟机的防火墙关闭。在桥接的作用下，类似于把物理主机虚拟为一个交换机，所有桥接设置的虚拟机连接到这个交换机的一个接口上，物理主机也同样插在这个交换机当中，所以所有桥接下的网卡与网卡都是交换模式的，相互可以访问而不干扰。



WinArpAttacker

查看攻击前信息

启动虚拟机XP1和XP2，查看虚拟机IP信息以及ARP缓存表，以及测试两个虚拟机是否可以相互ping。

```
C:\Documents and Settings\user>ipconfig
```

```
Windows IP Configuration
```

```
Ethernet adapter 本地连接 2:
```

```
Connection-specific DNS Suffix  . :  
IP Address. . . . . : 10.122.247.98  
Subnet Mask . . . . . : 255.255.192.0  
Default Gateway . . . . . : 10.122.192.1
```

实验示例图

```
C:\Documents and Settings\user>arp -a
```

```
Interface: 10.122.247.98 --- 0x2  
Internet Address      Physical Address      Type  
10.122.192.1          00-74-9c-7d-fa-db     dynamic
```

实验示例图



使用WinArpAttacker扫描在线主机，并找到靶机XP2。实施“禁止上网”的过程，浏览器测试XP2不能上网。Target IP address：10.122.192.1对应的是网关的地址，故网关会更新ARP缓存表，靶机10.122.252.138对应的MAC地址是不存在的。





(1)定时IP冲突：XP2的IP是10.122.252.138，然而该包的sender IP是10.122.252.138，故靶机认为局域网中存在IP和自己一样的端，错误地认为自己出现了IP冲突。

(2)不断IP冲突：包里内容和定时冲突一致，只是定时冲突发一个欺骗包，不断IP冲突发多个。

定时IP冲突 实验示例图

不断实验示例图





(2)查看数据包：中间人伪造了一个应答包，告诉XP2和XP3错误的映射关系，将MAC地址改成中间人的MAC

实验示例图

北京邮电大学信息安全中心



02

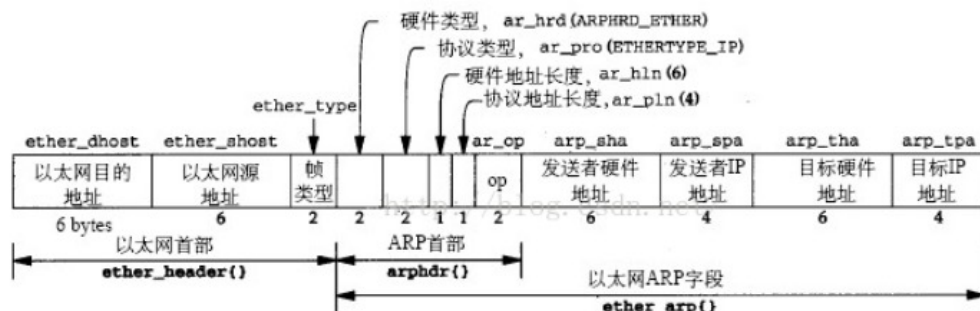
编程实验

选择Winpcap (或其它网络开发包
Libpcap/Jpcap/Scapy等) 编写ARP欺骗程
序 (禁止上网/IP冲突/中间人等)



编程实验

必须要把ARP中的每一个数据填充清楚，所以应该提前了解一下ARP报文的结构。



- ① 硬件类型:表明ARP实现在何种类型的网络上。
- ② 协议类型:代表解析协议（上层协议）。一般是0800，即IP。
- ③ 硬件地址长度:MAC地址长度，此处为6个字节。
- ④ 协议地址长度:IP地址长度，此处为4个字节。
- ⑤ 操作类型:代表ARP数据包类型。0表示ARP请求数据包，1表示ARP应答数据包。
- ⑥ 源MAC地址:发送端MAC地址。
- ⑦ 源IP地址:代表发送端协议地址（IP地址）。
- ⑧ 目标MAC地址:目的端MAC地址(待填充)。
- ⑨ 目标IP地址:代表目的端协议地址(IP地址)。



Jpcap

实验步骤

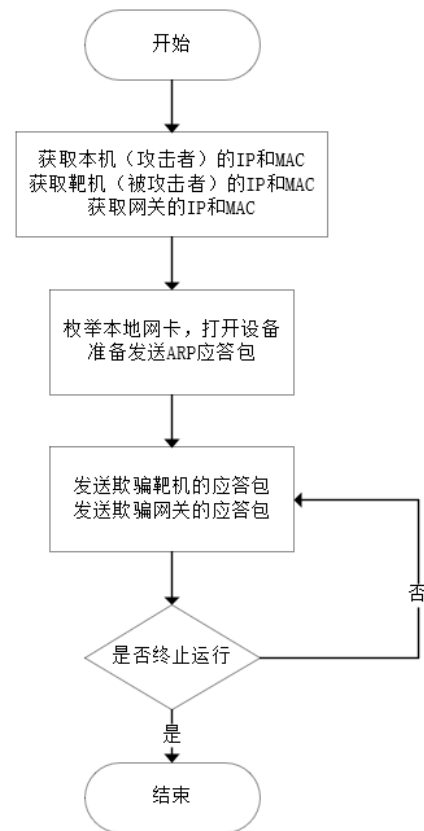
初步构想利用ARP欺骗，实现中间人攻击。攻击需要做到如下：

- ① 把靶机的ARP表中网关MAC改为攻击者MAC
- ② 把网关的ARP表中靶机MAC改为攻击者MAC

要想做到改变靶机**ARP**表中的表项，可以发送给靶机伪造的应答包。但因为主机会定时广播真实的对应信息，所以应该循环发送应答包，从而实现持续的**ARP**欺骗。为了维持靶机正常上网，需要在程序运行时开启**NAT**转发。

借助WinPcap来实现对数据链路层的相关操作，同时需要jpcap来作为沟通Java和WinPcap的媒介，所以应该提前安装WinPcap和jpcap。

同时，因为在生成ARP应答包时要通过ARPPacket类来生成。





Winpcap

✓ 攻击机

Win10

✓ 靶机

Windows XP SP3 2002

✓ 软件

Windows XP SP3 2002

实验步骤

使用Winpcap实现禁止上网攻击，构造一个ARP欺骗应答包，伪装成网关告诉靶机网关的MAC地址为不存在的地址，使靶机将错误的MAC地址映射更新到ARP表中，达到禁止上网攻击的目的。

1. 查看本机、受害者虚拟机以及网关的IP和物理地址，以及ARP缓存表，测试连通情况；
2. 根据ARP包格式定义数据包的数据结构；
3. 构造ARP欺骗包，欺骗受害者网关物理地址为一个不存在的地址。攻击者假装网关欺骗受害者网关的物理地址为不存在的IP；
4. 通过pcap_sendpacket发送数据包。



谢谢！